

Certificate Radar: понятный разбор проекта

Материал для подготовки к защите. Описывает реализованный MVP на 25 сентября 2026 года. Сначала прочитайте разделы 1–4, затем пример с VPN в разделе 6. Остальное пригодится для вопросов жюри.

Содержание

1. Что мы сделали — одним абзацем
2. Что такое сертификат и зачем за ним следить
3. Какую пользу получает компания
4. Как работает весь процесс
5. Три разных понятия: статус, проблема и риск
6. Откуда берётся риск 91
7. Какие проблемы ищет программа
8. Почему нужно два подключения
9. Имена, SNI и сканирование по IP
10. Что показывать на экране
11. Как устроены уведомления
12. Почему решение работает локально и что значит «только чтение»
13. Что уже сделано, а что пока нет
14. Демо: что происходит на самом деле
15. Частые вопросы жюри — готовые ответы
16. Что важно запомнить перед выходом
17. Где проверить детали в проекте

1. Что мы сделали — одним абзацем

Certificate Radar — локальное веб-приложение для системных администраторов и специалистов по информационной безопасности. Администратор задаёт адреса сервисов и запускает проверку. Программа получает их TLS-сертификаты, показывает сроки действия и обнаруженные проблемы, рассчитывает понятный приоритет, хранит ответственных и историю. Результат можно выгрузить в отчёт; при настройке каналов после сканирования отправляется сводка о приближении срока. Исправления на самих серверах выполняет человек.

Фраза для руководителя: **«Помогаем заранее увидеть проблемы сертификатов, понять, какой сервис важнее, и назначить ответственного за исправление».**

Это работающий прототип с интерфейсом, базой данных, тестами и локальным демонстрационным стендом. Измеренного экономического эффекта и промышленного внедрения пока нет.

2. Что такое сертификат и зачем за ним следить

Представьте удостоверение личности сайта. Когда клиент подключается к сервису, тот предъявляет сертификат: для каких имён он выпущен, кем подписан и до какой даты действует. Вместе с

проверкой ключей и доверия это помогает клиенту установить защищённое соединение с нужным сервисом.

Удостоверение может просрочиться, оказаться выписанным на другое имя или быть подписанным неизвестным издателем. Тогда клиент может отказаться подключаться. Сам сервер при этом иногда продолжает работать: проблема возникает именно при установлении доверенного соединения.

Для компании это может затронуть VPN, внутренний портал, API или другой сервис с прямым TLS-подключением. Один сертификат способен использоваться несколькими сервисами, поэтому «15 сервисов» и «15 уникальных сертификатов» — разные показатели.

Полезная аналогия: Radar — журнал осмотра удостоверений с приоритетами и ответственными. Он не выпускает новые удостоверения и не заменяет администратора.

3. Какую пользу получает компания

Кому	Что становится понятнее
Системному администратору	Что истекает, что настроено неправильно, что проверить первым
Специалисту ИБ	Где проблемы доверия, имени и криптографии
Руководителю ИТ	Какие важные сервисы требуют внимания и есть ли ответственные
Владельцу сервиса	Какое действие требуется и с каким сроком

Ценность проекта — объединить техническую проверку и организационную работу. Отдельная дата в таблице мало помогает, если непонятно, какой сервис важен и кто должен заняться перевыпуском.

Экономический эффект пока следует формулировать как гипотезу: меньше времени на ручную сверку и меньше вероятность пропустить проблему. Для пилота можно измерить время подготовки списка, количество найденных проблем и долю сервисов с назначенным владельцем. Суммы экономии без такого измерения обещать не нужно.

4. Как работает весь процесс

Адреса → TLS-проверка → анализ → приоритет и ответственный → уведомление или отчёт.

1. Администратор вставляет список или загружает TXT/CSV. Поддерживаются DNS-имя, IP, HTTPS-адрес, адрес с портом, IPv6 и ограниченная подсеть CIDR.
2. Программа разбирает список, убирает дубликаты и показывает ошибки с номерами строк. При наличии ошибок запуск нужно отложить до их исправления.
3. Для каждой цели выполняются TLS-рукопожатия: это начальный обмен при установлении защищённого соединения. Веб-страницы, пароли и содержимое сервиса не запрашиваются.
4. Сертификат разбирается: даты, имена, издатель, ключ, подпись и отпечатки. Отдельно проверяются доверие и соответствие имени.
5. Результат сохраняется в SQLite. Dashboard показывает последний результат по каждому сервису, а карточка — историю.

6. При настроенных каналах и достижении порога срока диспетчер отправляет сводку. Доступны CSV, Excel и HTML-отчёт для печати в PDF.

Порт по умолчанию — 443. Другой порт указывается в адресе. При вводе URL путь после имени не проверяется: Radar исследует TLS-сервис, а не конкретную страницу сайта. CIDR раскрывается в список IP; это не поиск всех портов и не обнаружение всей инфраструктуры автоматически.

В текущем MVP скан запускает пользователь кнопкой или запросом к API. Встроенного расписания нет. Без нового скана нельзя утверждать, что программа непрерывно следит за изменениями сервера. На Dashboard отображаются сохранённые наблюдения; нужно учитывать время проверки.

5. Три разных понятия: статус, проблема и риск

Именно здесь чаще всего возникает путаница.

Статус срока отвечает: «Сколько времени осталось до истечения?» По умолчанию:

Статус	Осталось полных дней
ОК	Больше 60
Информация	31–60
Предупреждение	15–30
Критический	0–14
Истёк	Меньше 0
Недоступно / ERROR	Сертификат не удалось получить

Дни считаются по UTC с округлением вниз. Например, 5 дней и 12 часов отображаются как 5 дней. Сразу после истечения получается отрицательное значение. В карточке даты действия подписаны UTC; это не местное время компьютера.

Пороги срока меняются в настройках и должны идти по убыванию: информация > предупреждение > критический $\geq$ 0.

Проблемы отвечают: «Что именно обнаружено?» Это срок, недоверенная цепочка, неправильное имя, слабый ключ и другие проверки. У каждого пункта есть пояснение и рекомендация.

Риск отвечает: «Какой сервис рассмотреть в первую очередь?» Он объединяет несколько факторов и важность сервиса в число от 0 до 100. Это условные баллы приоритета, **не процент вероятности аварии, не оценка ущерба и не сертификат соответствия стандартам.**

Поэтому статус ОК может соседствовать с заметным риском: до истечения далеко, но имя неверное или цепочка не доверена. А слово Critical может обозначать как статус срока, так и уровень риска — это разные поля.

6. Откуда берётся риск 91

Сначала начисляются баллы за срок. Из этой таблицы берётся одно значение:

Срок	Баллы
Больше 60 дней	0
31–60 дней	15
15–30 дней	35
8–14 дней	55
0–7 дней	70
Уже истёк	80

Затем добавляются факторы:

Фактор	Баллы
Самоподписанный сертификат	+20
Ошибка цепочки доверия	+25
Имя сервиса не совпадает	+25
Слабая криптография: ключ, подпись или старый согласованный TLS	+15 за всю группу
Не назначен владелец	+10

За самоподпись и ошибку цепочки одновременно два штрафа не складываются: берётся больший применимый. Слабый ключ и слабая подпись показываются как две проблемы, но дают +15 суммарно. Это защищает от повторного начисления за близкие причины.

Полученная сумма умножается на критичность сервиса: низкая $\times 0,85$; обычная $\times 1$; высокая $\times 1,15$; критичная $\times 1,3$. Итог округляется до целого и ограничивается 100.

Формула: риск = минимум из 100 и округлённой суммы баллов $\times$ множитель.

Уровни: 0–19 Low; 20–49 Medium; 50–79 High; 80–100 Critical.

Пример VPN из демо: до истечения 5 дней, цепочка и имя в порядке, владелец назначен, сервис критичный. За срок — 70. Дополнительных штрафов нет. $70 \times 1,3 = 91 \rightarrow$ **Critical**.

Пример weak: срок пока не близок, цепочка доверена, но RSA 1024 и подпись SHA-1. За криптографию +15, за отсутствие владельца +10, критичность обычная. $(15 + 10) \times 1 = 25 \rightarrow$ **Medium**.

Назначение владельца снимает организационный фактор, но не исправляет сертификат. Обычно это –10 до множителя; из-за округления и ограничения 100 видимая разница может быть другой. Оценка объяснимая и основана на фиксированных правилах — машинного обучения здесь нет.

При недоступном сервисе риск не рассчитывается: отсутствие данных нельзя превращать в нулевой риск. Проверка «ещё не действует» показывается отдельно; собственного слагаемого в текущей формуле у неё нет. Поэтому даже низкий риск не заменяет чтение списка проблем.

7. Какие проблемы ищет программа

Проверка	Простое объяснение	Что обычно делает администратор
EXPIRED	Срок уже закончился	Перевыпускает и устанавливает сертификат
EXPIRING	Срок приближается к настроенному порогу	Планирует перевыпуск
SELF_SIGNED	Сертификат подписан своим же ключом	Проверяет допустимость и при необходимости заменяет сертификатом доверенного УЦ
CHAIN_UNTRUSTED	Не удалось подтвердить доверие к цепочке	Проверяет промежуточные сертификаты и доверенные корни
HOSTNAME_MISMATCH	Подключились к одному имени, сертификат выдан для другого	Проверяет привязку сервиса и список имён в сертификате
WEAK_KEY	RSA меньше 2048 бит или EC меньше 256 бит	Перевыпускает с подходящим ключом
WEAK_SIGNATURE	Подпись использует SHA-1 или MD5	Перевыпускает с подходящим алгоритмом подписи
OLD_TLS	В соединении согласован TLS 1.0 или 1.1	Обновляет настройки протоколов сервера
NOT_YET_VALID	Дата начала действия ещё не наступила	Проверяет часы сканера и даты сертификата
NO_OWNER	Не указан ответственный	Назначает владельца сервиса
UNREACHABLE	Сертификат не удалось получить	Проверяет DNS, адрес, порт, сеть и доступность TLS

Это признаки для проверки, а не доказательства взлома. Например, недоверенный CA может быть обычным корпоративным центром, чей корневой сертификат ещё не добавлен на компьютер сканера.

8. Почему нужно два подключения

Обычная строгая проверка может оборвать соединение на плохом сертификате. Но именно такой сертификат нам и нужно изучить.

Первое подключение — наблюдение. Программа допускает проблемный сертификат, чтобы получить его данные. Это диагностическое действие, а не рекомендация пользователям отключать защиту браузера.

Второе — проверка доверия. Используются доверенные корни окружения Python/OpenSSL и дополнительно загруженные CA. Подключение идёт к тому же IP. Имя проверяется отдельной логикой приложения. Сертификаты двух подключений сравниваются, чтобы заметить подмену или смену сертификата между запросами.

Если строгий OpenSSL отказал из-за слабой криптографии или ошибки TLS-рукопожатия, возможна ещё одна проверка с пониженным уровнем безопасности. Тогда всего может быть три подключения. Доверие остаётся обязательным, а слабость криптографии фиксируется отдельными проблемами. В карточке прямо написано, что использован такой режим. Таймаут и закрытый порт не вызывают этот повтор.

Важные ограничения: это не полный повтор поведения всех браузеров; проверки отзыва нет. Сертификат, истёкший по времени, обозначается отдельно от проблемы цепочки. Коды OpenSSL 20/21 не позволяют однозначно отделить отсутствующий intermediate от неизвестного корня. Ссылка AIA даёт подсказку, но приложение не скачивает по ней сертификаты.

9. Имена, SNI и сканирование по IP

На одном IP могут жить несколько сайтов. **SNI** — имя, которое клиент сообщает в начале TLS-соединения, чтобы сервер выбрал сертификат нужного сайта.

Для DNS-цели Radar передаёт её имя. Для IP имени SNI нет, поэтому сервер может вернуть сертификат по умолчанию. Его несовпадение с IP не обязательно означает неправильную настройку доменного сайта: возможно, проверялась другая точка входа.

SAN — список имён и IP, на которые выдан сертификат. **CN** — отдельное имя в его полях. Реализация отдаёт приоритет SAN и допускает CN fallback, когда списки имён SAN отсутствуют. В том числе IP может сравниваться с CN, если SAN-имён нет. Поэтому не стоит заявлять, что проверка во всём идентична конкретному браузеру.

Шаблон `*.company.kz` покрывает `vpn.company.kz`, но не `company.kz` и не `a.b.company.kz`.

Один скан также не гарантирует проверку всех узлов за балансировщиком: фиксируется тот сервер и IP, к которому состоялось подключение. Отдельного выбора «IP + произвольное SNI» в интерфейсе MVP нет.

10. Что показывать на экране

На Dashboard есть число сервисов, число уникальных сертификатов, статусы срока, диаграммы, список самых высоких рисков и таблица. Можно фильтровать по владельцу, издателю, сроку, статусу, наличию проблем, искать по имени/CN/SAN и сортировать колонки.

Показатель здоровья — 100 минус средний рассчитанный риск доступных сервисов, с округлением. Недоступные сервисы в это среднее не входят. Поэтому высокий показатель здоровья не означает, что всё доступно: карточку недоступности нужно читать отдельно.

Карточка сервиса содержит даты UTC, имена, издателя, ключ и подпись, отпечатки, текст проверки OpenSSL, проблемы, рекомендации и историю. Владелец, название и критичность редактируются здесь же. Пересчёт после изменения данных не делает нового сетевого запроса и не подтверждает, что сертификат на сервере уже заменён.

Отпечаток — короткий идентификатор конкретного сертификата, полученный хешированием. Новый сертификат обычно даёт другой отпечаток. **Отпечаток SHA-1 не означает подпись сертификата SHA-1:** это разные поля и разные задачи. Слабая подпись определяется по алгоритму подписи, а не по наличию поля Thumbprint SHA-1.

Экспорт CSV/Excel берёт полный набор последних результатов, а не только строки текущего фильтра. Excel содержит три листа: сертификаты, сводку и проблемы. Печатный HTML можно сохранить в PDF через печать браузера.

11. Как устроены уведомления

Поддержаны Telegram, Email и Teams. Реквизиты задаются в `.env`; после изменения требуется перезапуск. Если канал не настроен, интерфейс так и сообщает. Для внешнего канала нужна связь с соответствующим сервисом, даже если само приложение работает офлайн.

После скана выбираются сертификаты с малым остатком срока. Пороги по умолчанию — 60, 30, 14, 7 и 1 день; для истёкших используется отдельный порог 0. Отправляется одна сводка на канал, а не сообщение на каждый сервис.

Сохраняется ключ «отпечаток сертификата + достигнутый порог + канал». Повторный скан не дублирует успешную отправку для того же ключа. При новом пороге или новом сертификате уведомление снова возможно. После неудачи можно повторить отправку. Кнопка «Отправить уведомления» принудительно повторяет текущую сводку.

Нюансы: выбирается наименьший уже достигнутый порог; пропущенные пороги не рассылаются задним числом. Один сертификат на нескольких сервисах делит ключ дедупликации. Это не индивидуальная маршрутизация владельцам: поле владельца отображается в тексте, а адресат определяется настройкой канала.

Сводка ориентирована на сроки. Высокий риск из-за слабой криптографии при далёком сроке сам по себе не означает отправку. Большая сводка сокращается и содержит ссылку на полный Dashboard. Успешная отправка снимает баннер последней ошибки; история ошибок остаётся в журнале.

Транспорты проверены с подменёнными HTTP/SMTP. Внешние доставки по реальным реквизитам в зафиксированных проверках не подтверждены. На защите можно говорить «каналы реализованы», а живую отправку обещать только после собственной проверки настроенного канала.

12. Почему решение работает локально и что значит «только чтение»

Приложение запускается на компьютере или сервере компании. Интерфейс, база и библиотека графиков находятся локально; CDN не нужен. При подготовленных зависимостях интернет для запуска не требуется. Доступ к самим проверяемым сервисам, разумеется, нужен.

«Только чтение» относится к целям: Radar выполняет TLS-рукопожатия, не логинится и не меняет конфигурацию серверов. В собственной базе он сохраняет результаты, историю, настройки и журнал. Уведомления — отдельные исходящие сообщения в настроенные каналы.

Без агентов означает, что на каждый проверяемый сервер не нужно устанавливать нашу программу. Закрытые ключи целевых серверов для проверки не требуются и не извлекаются.

Любая сетевая проверка создаёт нагрузку и может попасть в журналы. Поэтому «только чтение» не равно «нулевое воздействие». Параллельность и таймаут регулируются. По умолчанию одновременно работают до 32 задач, таймаут подключения — 4 секунды. Один процесс обслуживает один скан за раз.

По умолчанию приложение доступно только локально. Встроенных пользователей, паролей и ролей для доступа к интерфейсу пока нет. Для пилота доступ ограничивают доверенным административным окружением. Токены уведомлений хранятся в `.env`, а не в базе; в интерфейсе они маскируются.

13. Что уже сделано, а что пока нет

Уже есть	Пока нет
Сканирование заданных прямых TLS-сервисов	Автосканирование по расписанию
Даты, доверие, имена и базовые криптографические проверки	Проверка отзыва OCSP/CRL
Объяснимые баллы, владельцы и критичность	Автоматический перевыпуск и установка сертификатов
Dashboard, история, экспорт и журнал	Авторизация пользователей и роли
Корпоративные доверенные CA	STARTTLS для протоколов, где TLS включается отдельной командой
Каналы уведомлений с дедупликацией	Полный перебор всех версий TLS и шифров сервера
Локальный демонстрационный стенд	Кластерная работа и промышленный SLA

Если соединение договорилось о TLS 1.3, это ещё не доказывает, что сервер запрещает TLS 1.0: полного перебора протоколов нет. Программа оценивает наблюдаемый результат подключения.

Лимиты по умолчанию: файл до 1 МБ, до 2048 целей за скан, CIDR до 1024 адресов. SQLite подходит текущему локальному MVP; нагрузочное тестирование большого промышленного окружения не заявляется.

Проверен запуск в Windows. Код и `run.sh` предусматривают Linux, но отдельного полного прогона на Linux в зафиксированной проверке нет.

Развитие можно предложить так: сначала пилот и обратная связь, затем расписание, разграничение доступа и нужные интеграции. Подключение новых коллекторов и проверок заложено модульной архитектурой, но будущие DNS/Identity/Backup-модули ещё не реализованы.

14. Демо: что происходит на самом деле

Демонстрационный стенд — локальный TLS-сервер с настоящими специально подготовленными сертификатами. Он выбирает сертификат по SNI. Наблюдения получаются через реальные TLS-соединения; неисправности созданы намеренно.

Цель	Что показать
valid / wildcard	Корректный сертификат и проверку имени
info / warn / soon	Разные сроки и статусы
vpn	5 дней, критичный сервис, назначенный владелец, риск 91
expired	Истёкший сертификат
selfsigned	Самоподпись и издателя Self-Signed Test
untrusted	Неизвестный корень, издателя Rogue Issuer Ltd
nochain	Отсутствующий промежуточный сертификат
mismatch	Несовпадение имени
weak	Слабый ключ и подпись при доверенной цепочке, риск 25
dead	Недоступную цель, отсутствие расчёта риска

У обычных сертификатов издатель — Lab Corporate PKI. В фильтре также есть «—» для недоступных целей. Демо-список даёт 15 целей, включая два IP; сертификатов может быть меньше, поскольку один используется повторно.

Подготовка до выступления

Подробные команды есть в README. Подготовку выполняют вручную на демонстрационной копии: остановить приложение и стенд, пересоздать сертификаты через `python -m lab.generate_certs`, очистить демонстрационную БД `data/radar.db*`, затем запустить всё заново. Очистка удаляет историю и настройки, поэтому это не действие для рабочей базы компании.

Перезапуск стенда обязателен: старые сертификаты остаются в памяти процесса. Свежая генерация сохраняет пример «5 дней → 91». Если сертификаты состарились, число дней изменится. Настройки доверенных СА должны соответствовать новому лабораторному корню.

Проверьте hosts, доступность приложения, наличие демонстрационных целей и PDF презентации. Если собираетесь показывать живое сообщение, заранее протестируйте канал. Во время пяти минут подготовки и установки зависимостей быть не должно.

Короткий показ на 45–50 секунд

1. Заранее выполните: демо-CSV → «Применить сведения» → демо-список → скан. Именно CSV назначает VPN владельца и критичность.
2. Во время выступления откройте готовый Dashboard: «Здесь список сервисов и очередь внимания».
3. Откройте VPN: «5 дней, 70 баллов за срок, множитель 1,3 — итого 91».
4. Покажите владельца и рекомендацию: «Понятно, кому поручить действие».

Это заменяет рассказ по слайду 4, а не добавляет ещё минуту. Если стенд недоступен, используйте скриншот в презентации и не тратьте питч на отладку.

15. Частые вопросы жюри — готовые ответы

Зачем это компании? Чтобы собрать проверку сертификатов, приоритеты и ответственность в одном месте. Ожидаемый эффект — меньше ручной сверки и меньше пропущенных проблем; его нужно измерить на пилоте.

Чем это отличается от таблицы? Таблица хранит введённые сведения. Radar сам получает сертификат с заданного сервиса при скане, проверяет его, хранит историю и объясняет приоритет. Экспорт в таблицу остаётся доступен.

Чем лучше существующего мониторинга? Мы не заявляем, что лучше всех продуктов. Наш акцент — локальный запуск и единый сценарий «причина → приоритет → владелец → отчёт». В пилоте нужно проверить, насколько это дополняет инструменты компании.

Это искусственный интеллект? Нет. Риск считается по прозрачным правилам. Пользователь видит каждое слагаемое.

Откуда 91? 70 за пять дней до истечения, умноженные на 1,3 за критичность VPN. Это баллы приоритета, не 91% вероятности сбоя.

Что исправляется автоматически? На целевых серверах ничего. Программа обнаруживает, объясняет и сообщает; перевыпуск и установка остаются за администратором.

Почему у слабого сертификата доверенная цепочка? Доверие к издателю и качество криптографии — разные проверки. У него остаются предупреждения о слабом ключе и подписи, но нет выдуманной ошибки цепочки.

Можно работать без интернета? Да, для локальных доступных целей и при заранее подготовленных зависимостях. Внешние каналы уведомлений требуют отдельной связи.

Нужно ставить агент на каждый сервер? Нет, проверка выполняется по сети через TLS. На каждый целевой сервер наш код не устанавливается.

Какие доказательства работоспособности? В PROGRESS.md зафиксированы 117 успешных автотестов, в том числе 14 TLS-тестов, и два полных браузерных демо после последних правок. 14 входят в 117, складывать эти числа нельзя.

Что со скоростью? На локальном стенде проверен сценарий 50 целей менее чем за 15 секунд. Ранее зафиксировано около 1,8 секунды. Это результат конкретного стенда, не обещание скорости любой сети.

Готово ли к широкому промышленному внедрению? Пока это MVP для контролируемого пилота. Нужны оценка доступа, расписание, эксплуатационные требования и проверка масштаба конкретной компании.

Какой следующий шаг? Выбрать группу TLS-сервисов, сверить находки с администраторами, назначить владельцев и подтвердить исправления повторным сканом. Измерить полезность, затем решать о развитии.

16. Что важно запомнить перед выходом

- Radar помогает человеку принять решение: что проверить первым и кому поручить.
- Статус — срок. Проблемы — причины. Риск — приоритет с учётом важности сервиса.
- $91 = 70 \times 1,3$. Это не процент.
- Сканирование сейчас запускается вручную. Автоматический перевыпуск не реализован.
- Реальные сертификаты и TLS-соединения в демо; специально созданные неисправности.
- Не обещайте отсутствие инцидентов, измеренную экономию или полноценную замену всей системы мониторинга.

17. Где проверить детали в проекте

Источники для этого разбора — текущая реализация, README.md и PROGRESS.md. Внешняя статистика инцидентов в питче не используется.

Тема	Файл
Даты и статусы	app/analysis/status.py
Формула риска	app/analysis/risk.py и app/config.py
Список проверок	app/analysis/checks.py
TLS и повторная проверка	app/collectors/tls_collector.py
Правила имён	app/analysis/hostname.py
Сканирование и сохранение	app/scanner.py и app/repository.py
Уведомления	app/notifiers/dispatcher.py
Результаты проверок	PROGRESS.md
Подготовка стенда	README.md и lab/generate_certs.py